



北京邮电大学

软件安全

北京邮电大学网络空间安全学院

张淼

zhangmiao@bupt.edu.cn

北京邮电大学

BEIJING UNIVERSITY OF POSTS AND TELECOMMUNICATIONS



第一讲 概述

- 1 信息安全概述
- 2 信息安全的困境
- 3 问题的原因和根源
- 4 主要解决途径-软件安全
- 5 本课程的主要内容

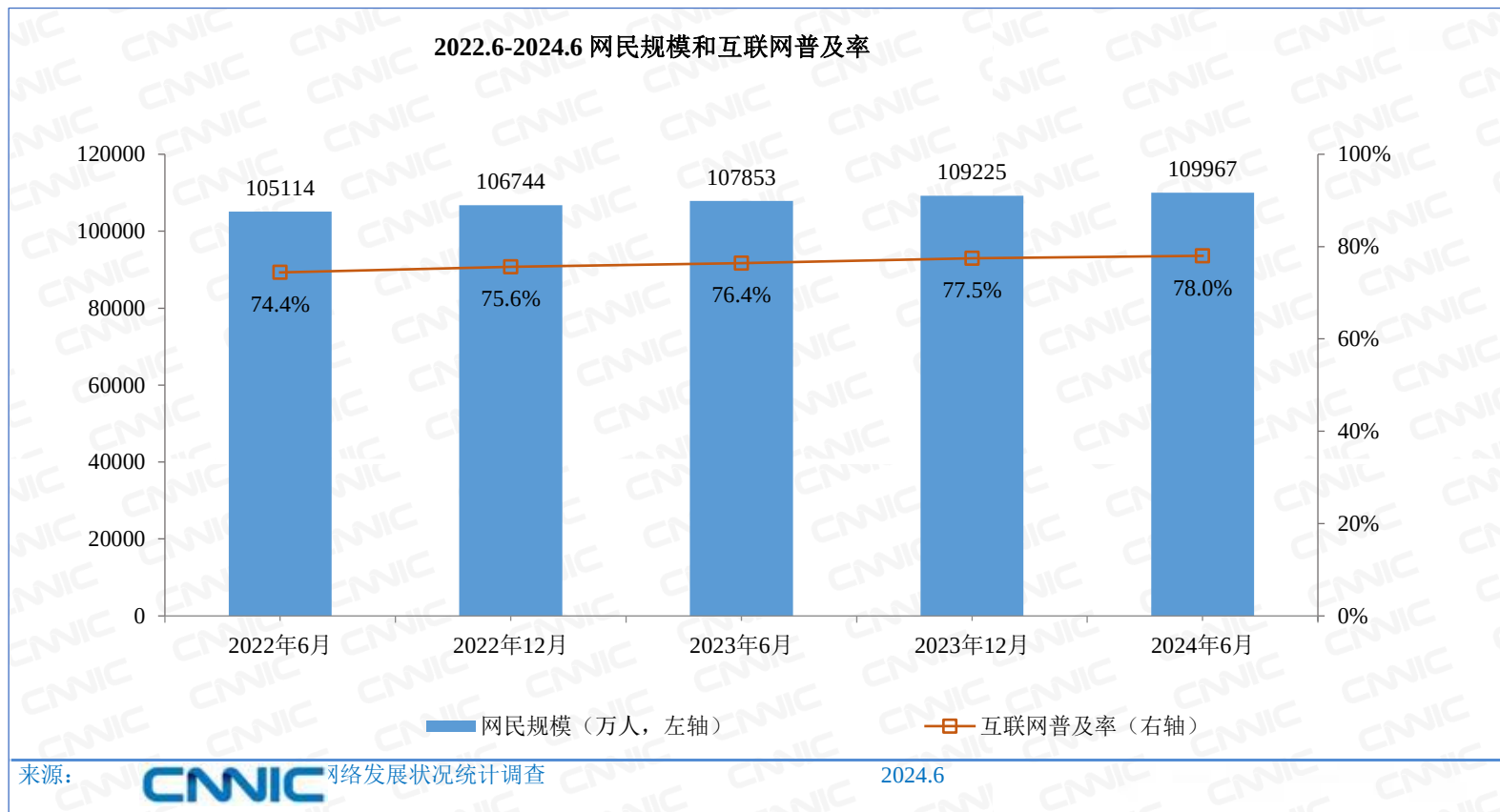


1 信息安全概述

- 信息技术发展
- 信息安全现状
- 信息安全威胁
- 信息安全含义



信息技术发展



截至2024年6月底，我国网民规模达10.96亿；网民中使用手机上网人群占比99.7%



主要的网络应用

应用	2023.12 网民规模 (万人)	2023.12 网民 使用率	2024.6 网民规模 (万人)	2024.6 网民 使用率	增长率
即时通信	105,963	97.0%	107,787	98.0%	1.7%
网络视频 ¹	106,671	97.7%	106,796	97.1%	0.1%
短视频	105,330	96.4%	105,037	95.5%	-0.3%
网络支付	95,386	87.3%	96,885	88.1%	1.6%
网络购物	91,496	83.8%	90,460	82.3%	-1.1%
搜索引擎	82,670	75.7%	82,440	75.0%	-0.3%
网络新闻	77,191	70.7%	76,441	69.5%	-1.0%
网络直播	81,566	74.7%	77,654	70.6%	-4.8%
网络音乐	71,464	65.4%	72,914	66.3%	2.0%
网上外卖	54,454	49.9%	55,304	50.3%	1.6%
网络文学	52,017	47.6%	51,602	46.9%	-0.8%
网约车	52,765	48.3%	50,270	45.7%	-4.7%
在线旅行预订	50,901	46.6%	49,721	45.2%	-2.3%
互联网医疗	41,393	37.9%	36,532	33.2%	-11.7%
网络音频	33,189	30.4%	31,976	29.1%	-3.7%



- 信息化已渗透到社会的方方面面：

- ➔ 生活：三网融合、物联网、电子商务、车联网
- ➔ 娱乐：即时通信、微博、网络游戏、数字家庭
- ➔ 生产：电子政务、移动OA、工业控制
- ➔ 通信：宽带、蓝牙、WiFi、卫星通信、6G……
- ➔ 城市信息化：智能交通、票务、场馆、通信、CMMB、无线城市……
- ➔ ……



- 热点技术

- ➔ 移动互联网

- ➔ AIGC/LLM

- ➔ VR/AR

- ➔ SNS

- ➔ 云计算

- ➔ 物联网

- ➔ 手机支付、无线射频识别（RFID）



信息安全现状

●信息安全现象

→ 病毒、黑客攻击的泛滥

- 数量规模大、智能程度高（技术含量）、组织方式多样化（个人、组织和集团等）……
- 危害程度严重

→ 信息安全成为国家安全的重要内容

- 国家领导层的意识
- 信息化建设的经验、伊战的教训……

→ 关键技术受制于人

- CPU、OS……
- 专利、标准……



→ 行业市场重点突出

- 随着WTO保护期临近结束，金融、政府、电信等重点行业在机构改革和业务创新的同时，IT系统建设和整合不断深入，这为安全产品提供了广阔的市场空间，这三个行业是安全产品最大的市场，同时政府行业和电信行业近两年都将保持35%以上的快速增长；而能源、流通等行业的安全需求增长态势迅猛

→ 市场竞争激烈，安全服务和产品创新成为厂商竞争焦点

- 竞争激烈，强强联合
- 安全服务市场成为安全厂商竞争的焦点。
- 产品创新主要表现在集成式产品。



信息安全威胁

●信息安全威胁的表现:

- 网络协议的弱点
- 网络操作系统的漏洞
- 应用系统设计的漏洞
- 网络系统设计的缺陷
- 恶意攻击
- 来自合法用户的攻击
- 互联网的开放性
- 物理安全
- 管理安全



● 威胁的根源

➔ 信息系统的复杂性:

- 系统软硬件缺陷，网络协议的缺陷

➔ 信息系统的开放性:

- 系统开放：计算机及计算机通信系统是根据行业标准规定的接口建立起来的。
- 标准开放：网络运行的各层协议是开放的，并且标准的制定也是开放的。
- 业务开放：用户可以根据需要开发新的业务。



信息安全含义

●信息安全的六个方面：

- ➔ 保密性 (C, confidentiality) : 信息不泄漏给非授权的用户、实体或者过程的特性
- ➔ 完整性 (I, integrity) : 数据未经授权不能进行改变的特性, 即信息在存储或传输过程中保持不被修改、不被破坏和丢失的特性。
- ➔ 可用性 (A, availability) : 可被授权实体访问并按需求使用的特性, 即当需要时应能存取所需的信息。
- ➔ 真实性: 内容的真实性
- ➔ 可核查性: 对信息的传播及内容具有控制能力, 访问控制即属于可控性。
- ➔ 可靠性: 系统可靠性



- 信息安全特性

- ➔攻防特性：攻防技术交替改进
- ➔相对性：信息安全总是相对的，够用就行
- ➔配角特性：信息安全总是陪衬角色，不能为了安全而安全，安全的应用是先导
- ➔动态性：信息安全是持续过程



- 信息安全范围（存在IT应用的任何场景）

- ➔管理与技术

- ➔密码、网络攻防、信息隐藏

- ➔单机、服务器、数据库、应用系统

- ➔灾难恢复、应急响应、日常管理

- ➔.....



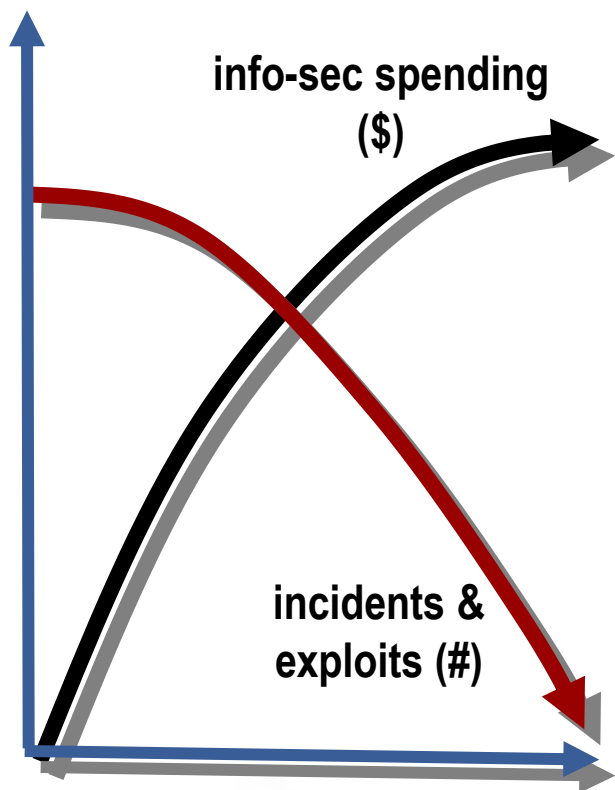
2 信息安全的困境

- 信息安全的需求
- 主要的困难
- 软件安全的越来越受到重视



安全的需求

- 用户花费了很大的代价来解决信息安全风险，希望能够：



保护业务不会被黑客破坏”



限制责任和义务,满足法规和标准



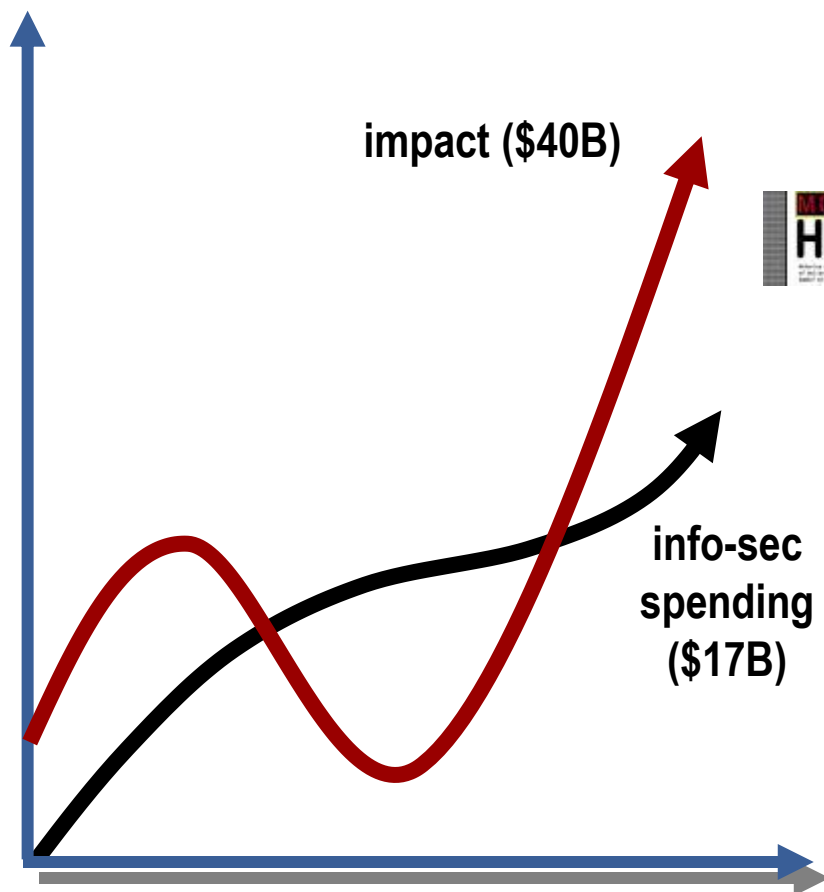
避免对企业的品牌和信誉造成破坏





安全面临的困境

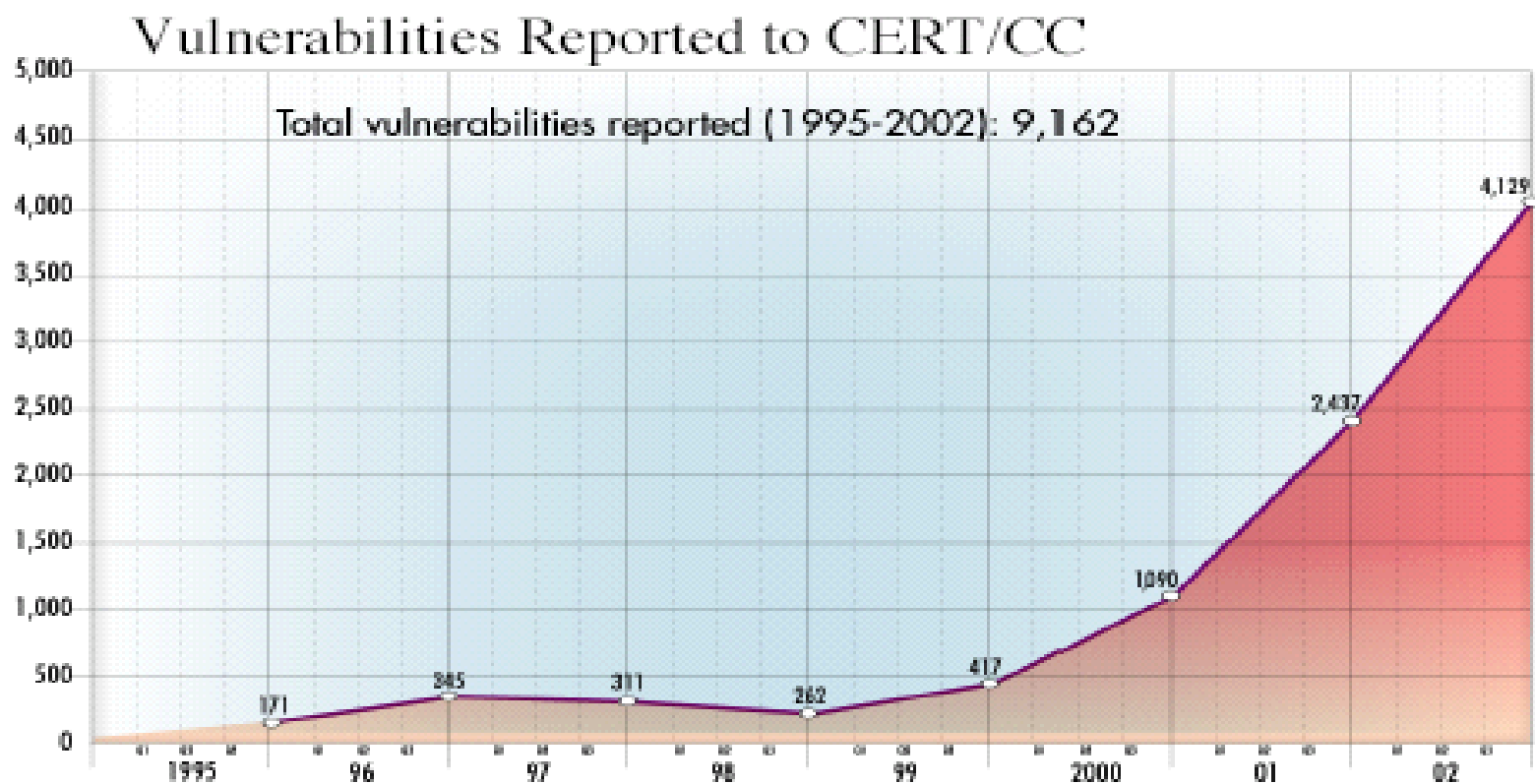
- 然而事实上，很多企业每年都花了数百万的资金在安全上，但是效果并不如意，信息安全问题越来越多。



breaches grow dramatically - seriously impacting: **uptime, regulatory compliance, liability, brand and reputation**

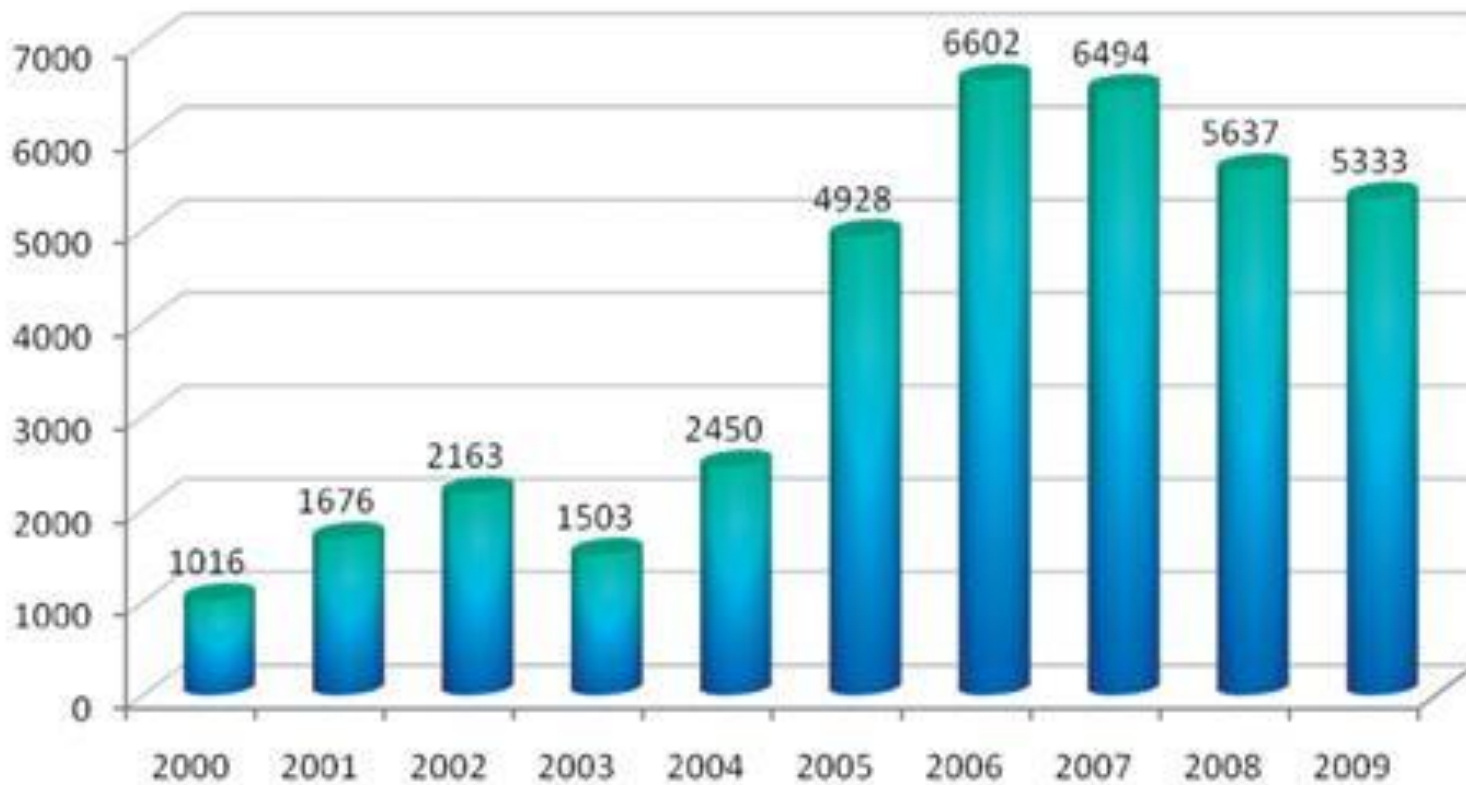


软件安全漏洞的发展趋势





近10年来漏洞数量增长趋势



国家漏洞库CNNVD



CERT 2006的报告

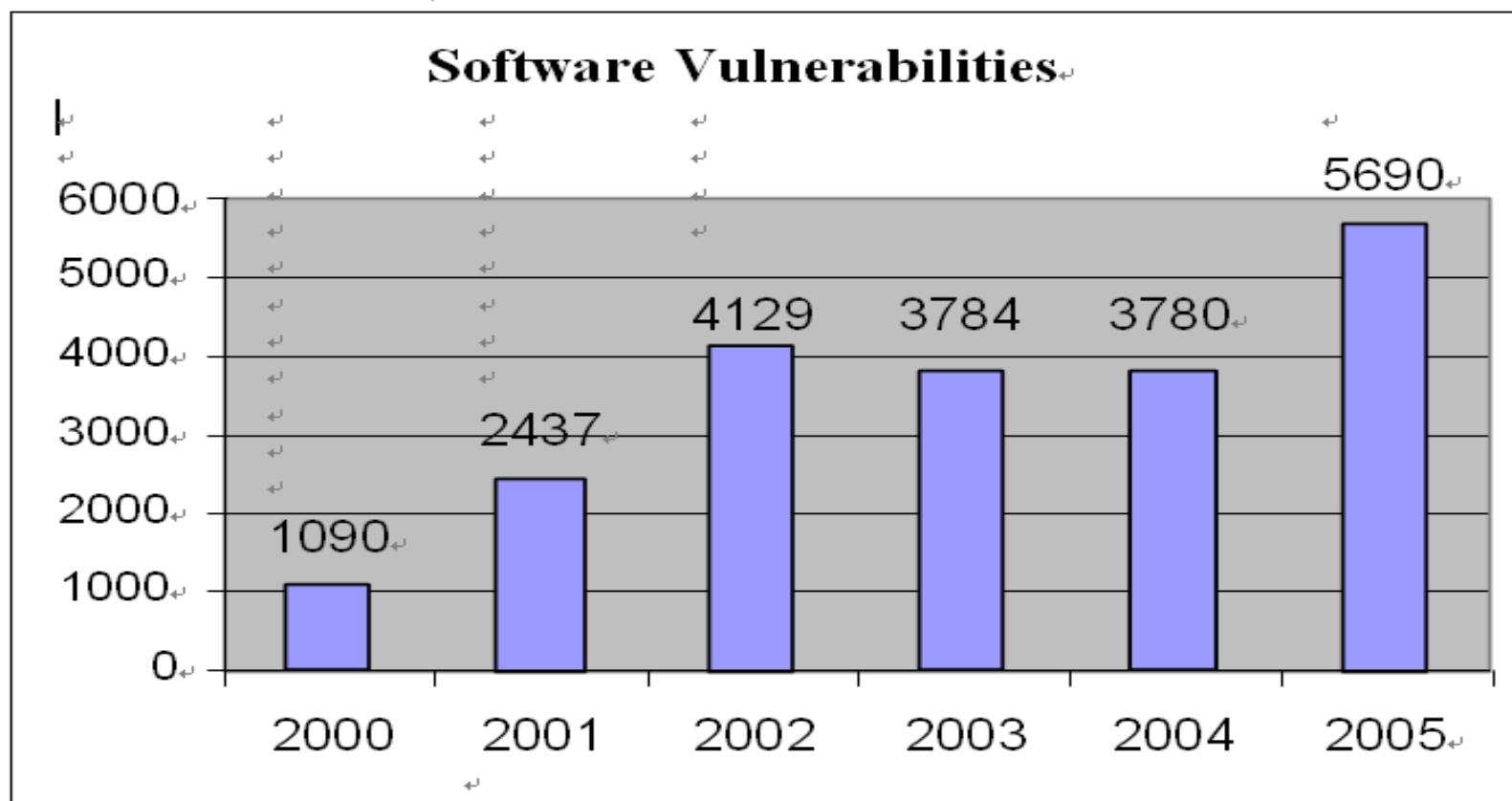
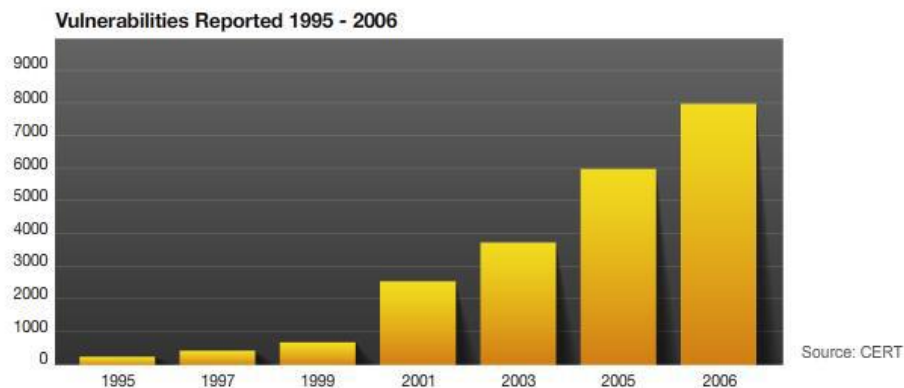


Figure 1: Vulnerability data from CERT.



- **143,757,645** 个安全风险记录自2005年来被报告

- **45%** 的被调查者不清楚自己的系统上可能存在的安全隐患



- **+106%** 从2006年以来,报告数量由于第三方厂商以及各种开发商和咨询商的参与而大幅度增长

- **40%** 的被调查者不清楚每年发生的安全事件

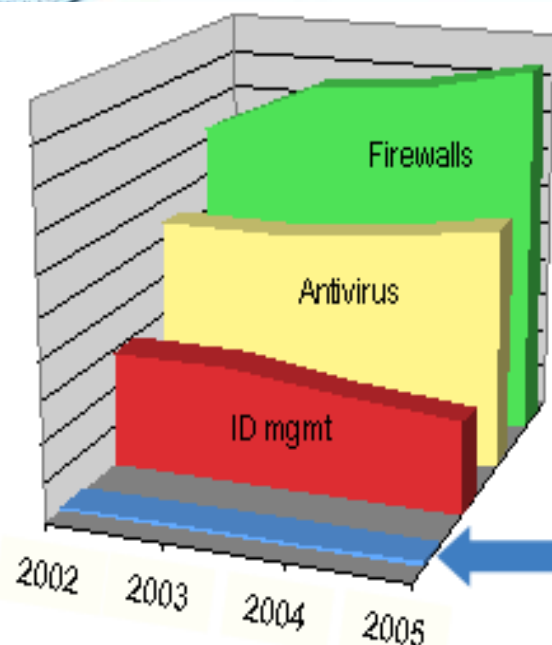


原因是什么？

- **钱花在哪儿去了？**
- **为什么信息安全方面的工作收效甚微？**



传统解决方案和投资方向



So what are companies doing? ?

... buying more firewalls!



The network can't fix broken software. Developers must do that.

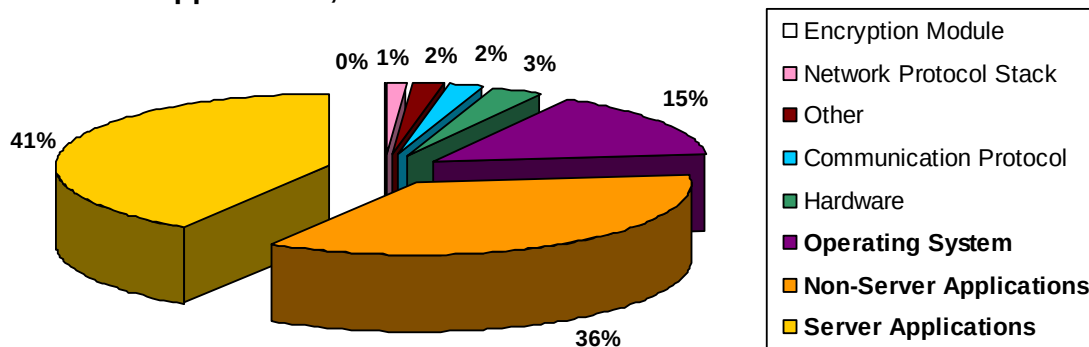
\$ Millions	2002	2003	2004	2005 (e)
Security in the Development Lifecycle (SDLC)*	\$ 25~30	\$ 25~30	\$ 50	\$ 60
Identity Management (Access control / Authentication)	\$ 900	\$ 1,052	\$ 1,178	\$ 1,315
Virus Prevention	\$ 1,680	\$ 1,954	\$ 2,632	\$ 3,550
Firewalls and <u>VPNs</u> (Network Security)	\$ 2,241	\$ 3,081	\$ 4,121	\$ 5,480



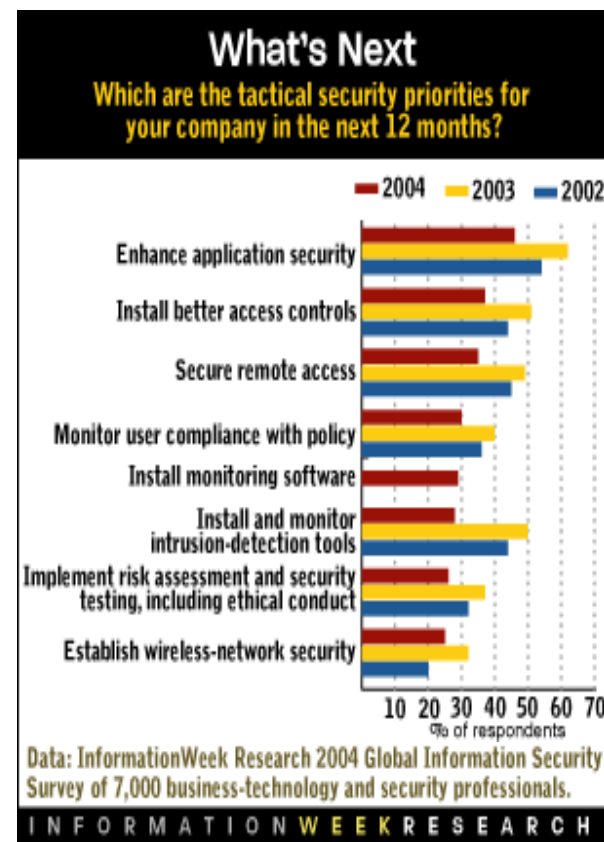
软件安全问题正日益成为信息安全问题的焦点

超过70%的安全漏洞出现在应用层而不是网络层。而且不只发生在操作系统或者web浏览器，而发生在各种应用程序中-特别是关键的业务系统中。

92% of reported vulnerabilities are in applications, not networks



Source: NIST





3 问题的原因和根源

- 软件问题的原因
- 黑客攻击方式的进化
- 传统技术的不足
- 传统安全教育的不足
- 软件安全的根源问题



软件问题的原因

- Connectivity (互联性)
- Extensibility (扩展性)
- Complexity (复杂性)



互联性

- 终端设备的互联给了攻击者有更多的机会
- 攻击者利用系统弱点不再需要进行物理访问
- 平台设计缺陷
 - ➔ 不支持特定的安全功能，例如SSL、认证授权机制等
 - ➔ 典型问题：无线蹭网卡



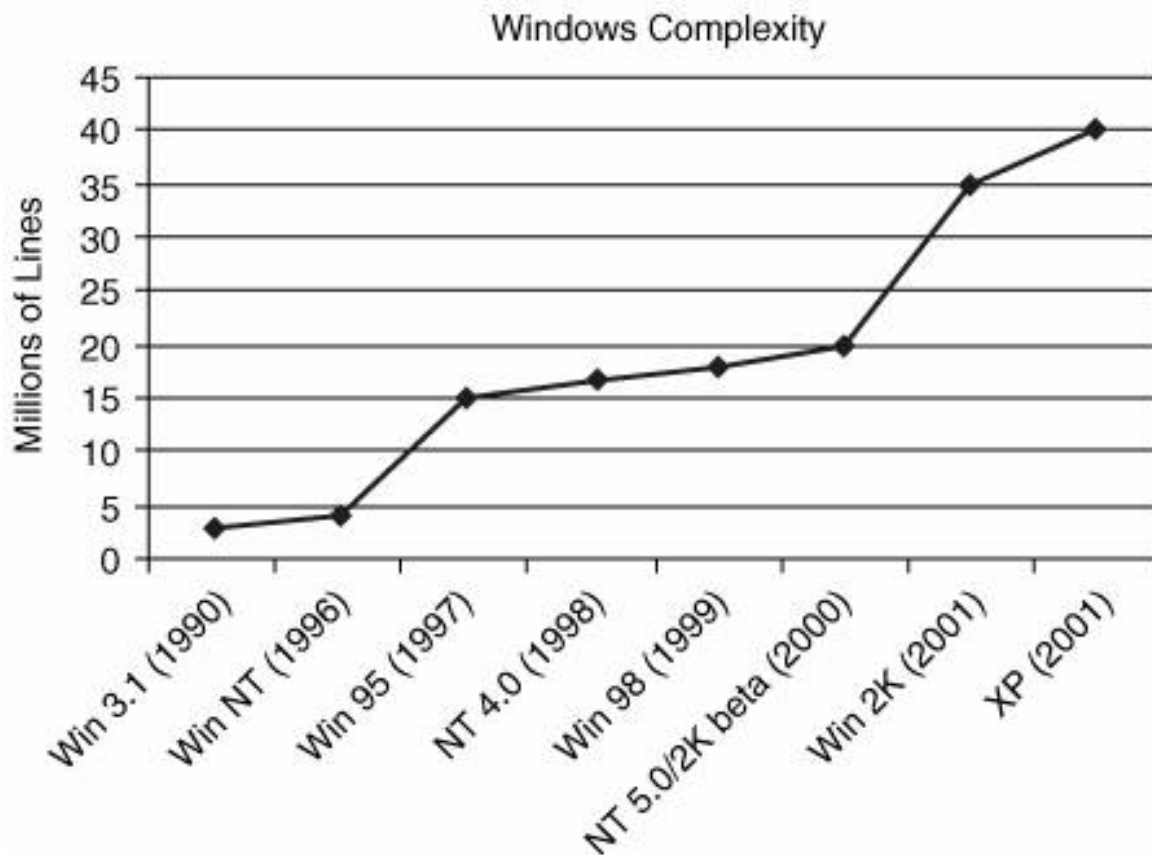
扩展性

- 目前很多软件技术都支持扩展技术
 - ➔ 通过脚本、控件、组件、**applet**等形式
 - ➔ 在**J2EE**、**.NET**技术里中比较常见
- 优点在于可以很方便的加载以及扩展新的功能与组件
- 问题在于扩展的功能与组件不可控，会带来未知的安全风险



9000个开发人员，花费了60亿美元，
历时5年完成

- 软件系统代码增长速度惊人 Vista: 50,000,000行





- 除了Windows，其他软件的代码量得增长速度也是非常快

19xx	SCOMP	20,000
1979	Multics	1,000,000
2000	Red Hat 6.2	17,000,000
2000	Debian.GNU/Linux 2.2	55,000,000
2000	Linux 2.2 kernel	1,780,000
2000	XFree86 3.3.6	1,270,000
2001	Red Hat 7.1	30,000,000
2002	Mac OS X Darwin kernel	790,000

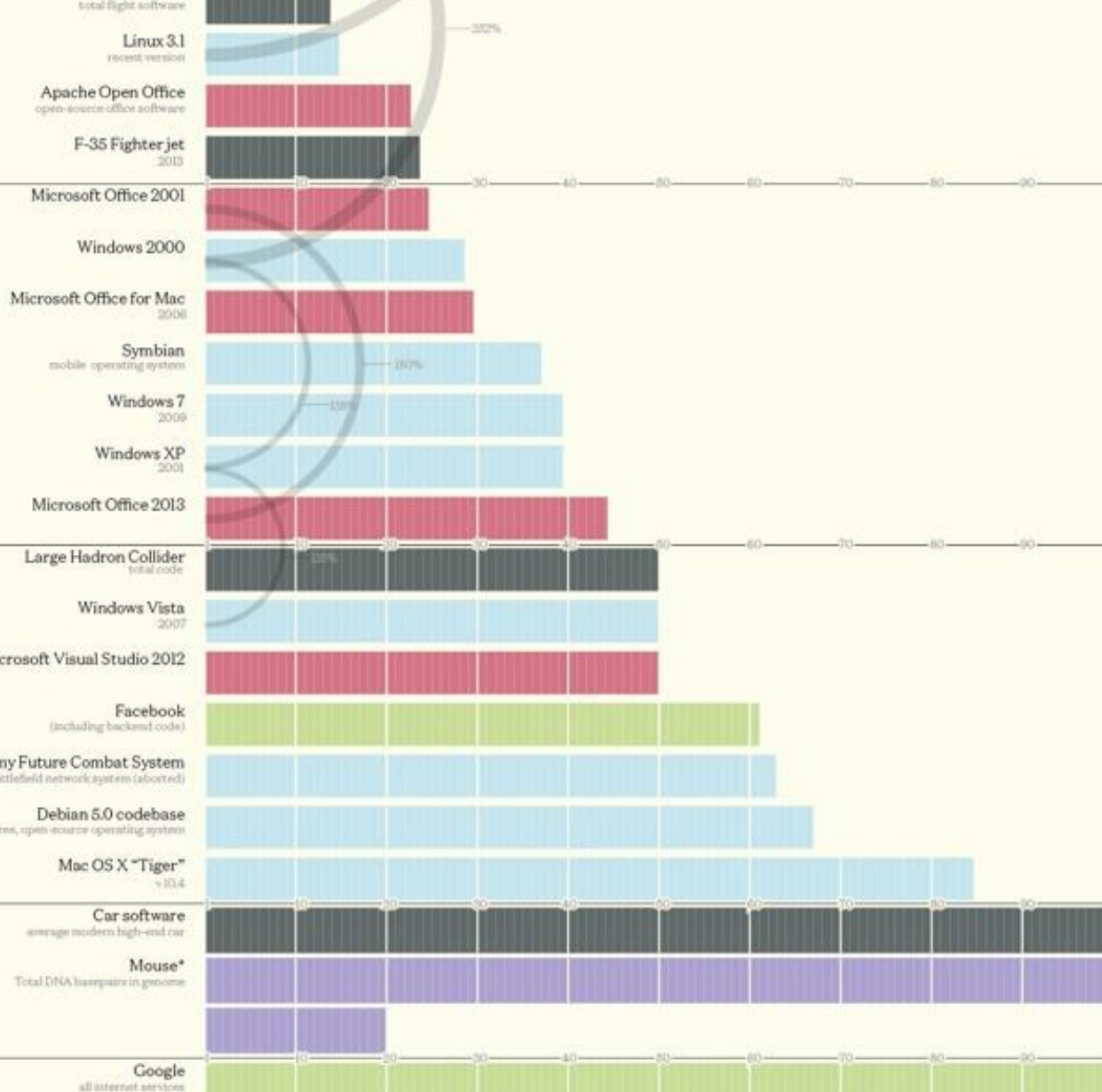


-25

-50

-100

-2 billion





- 系统越复杂，Bug越难避免，质量越难保证，可能发生的安全风险越多。

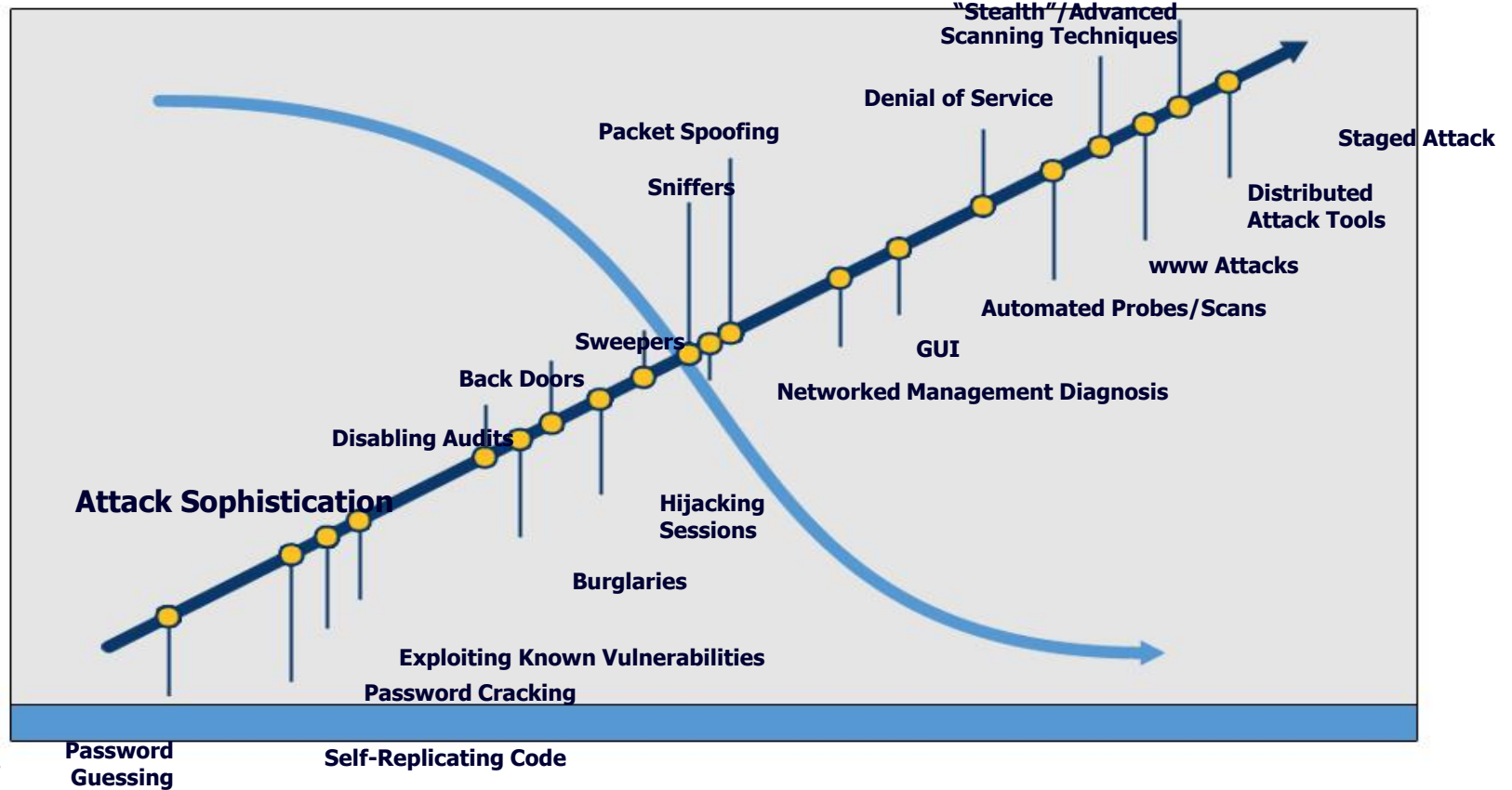


攻击方式的演化

需要的黑客知识

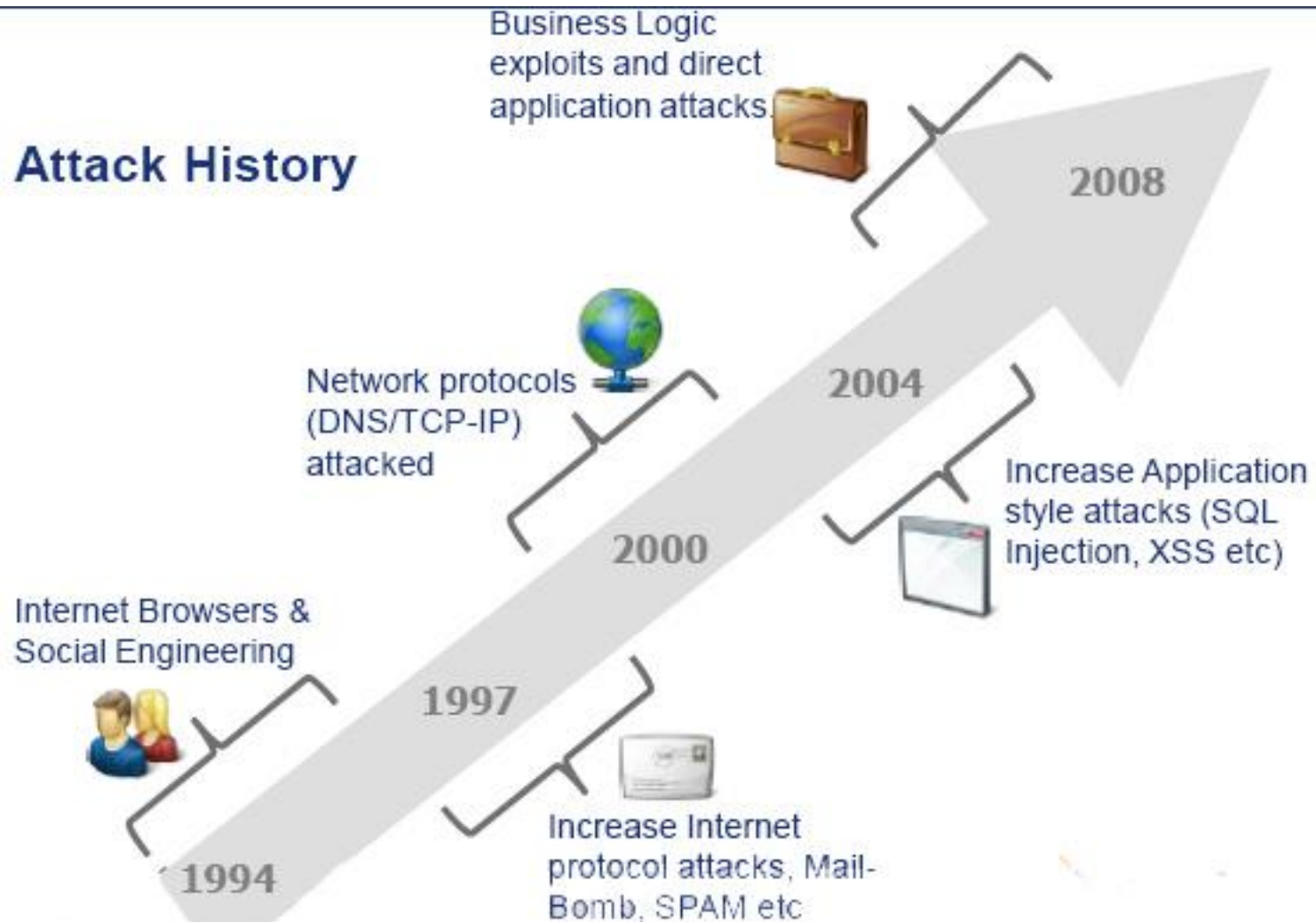
HIGH

Cross-Site Scripting



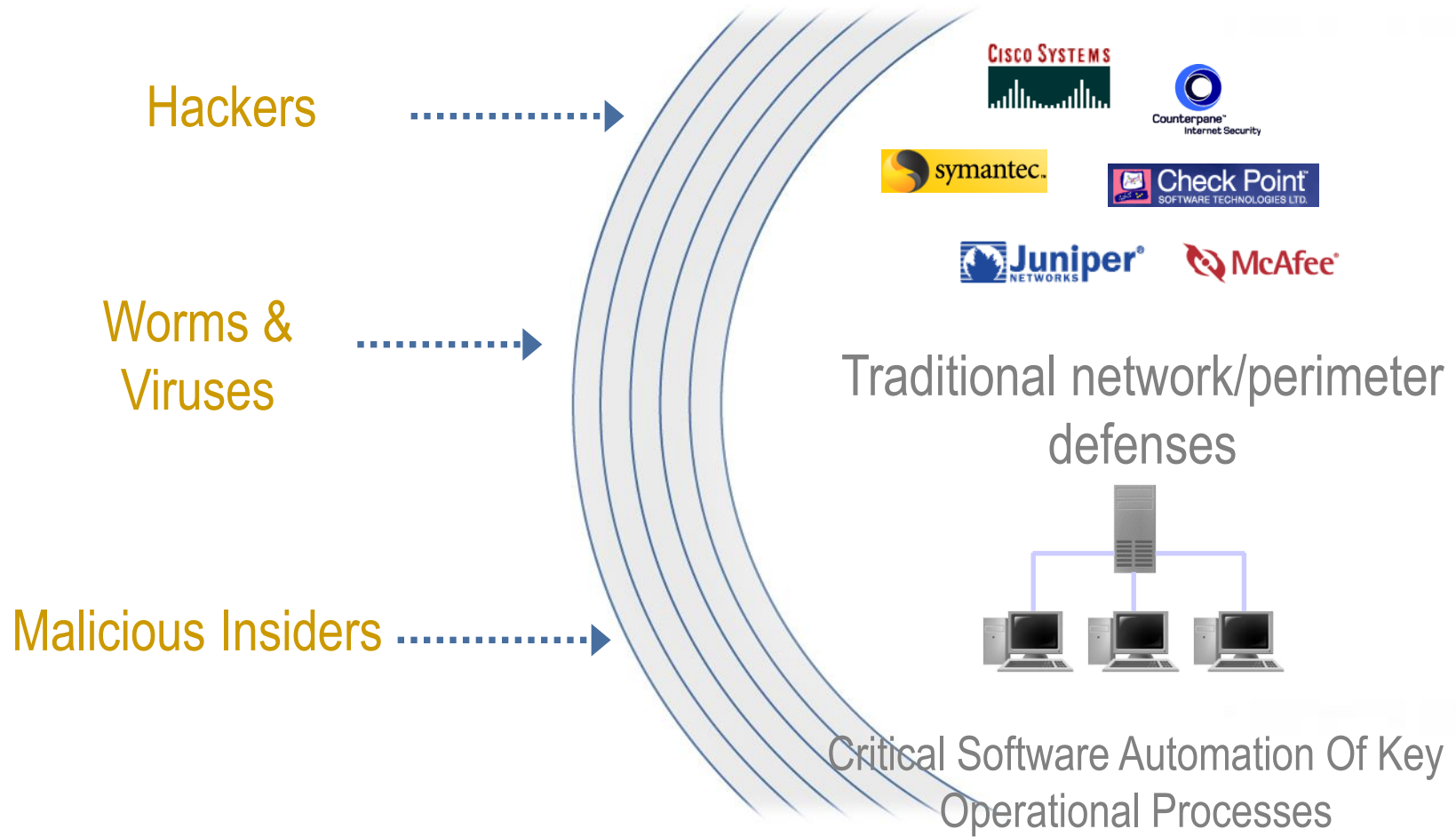


Attack History



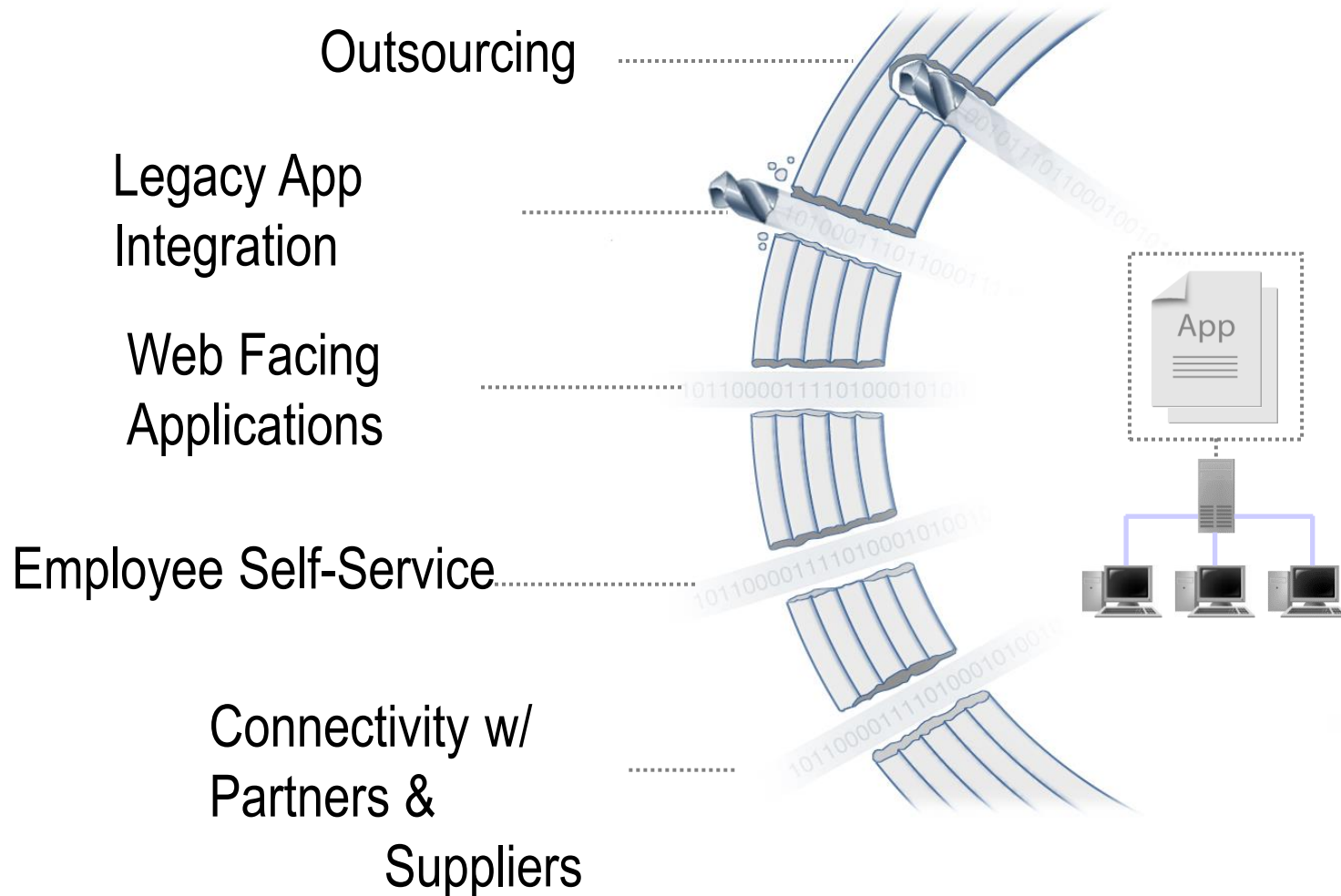


传统的分层保护方案



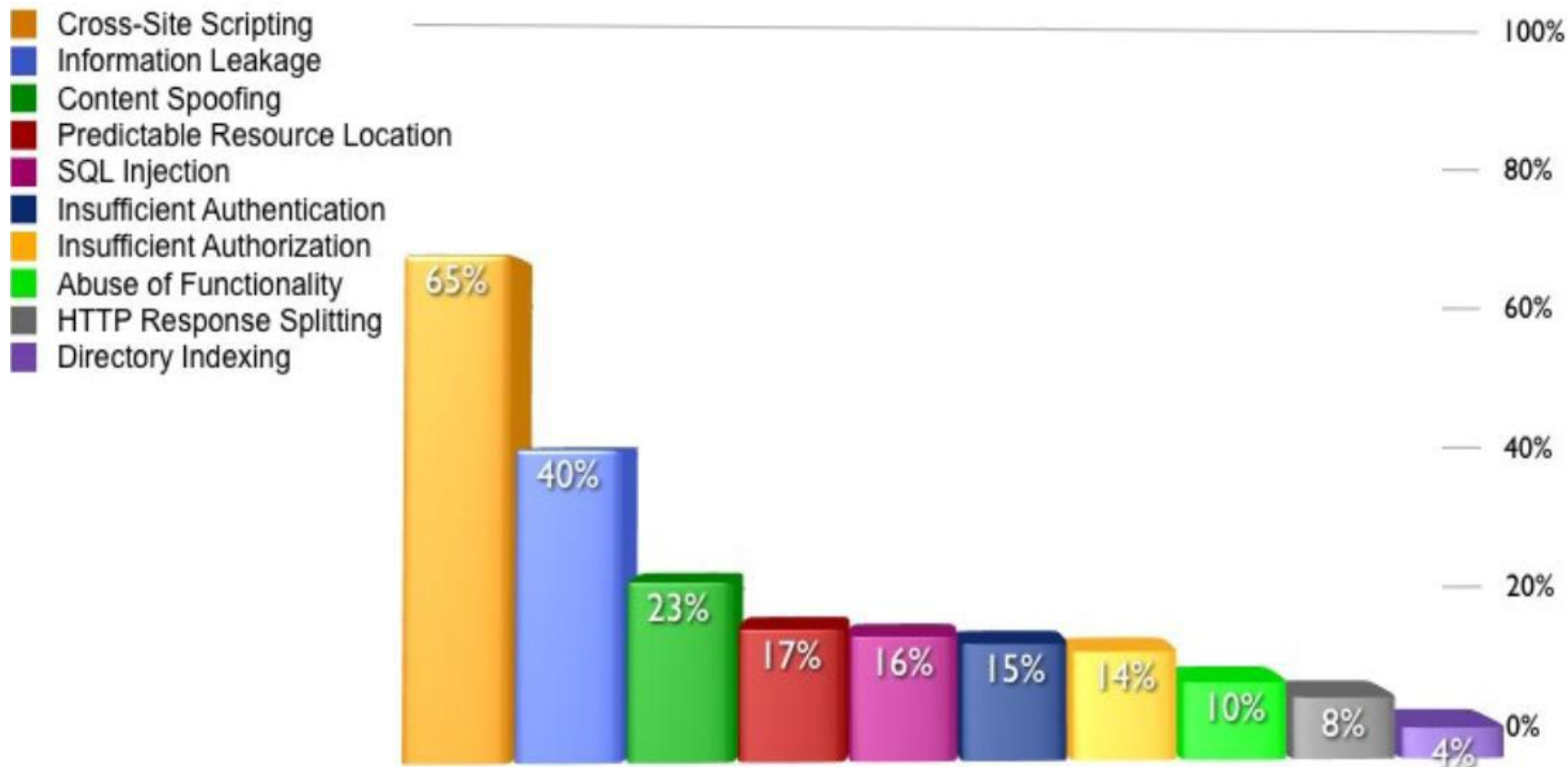


软件的应用因为业务和功能的需要必须
打破传统的保护层,直接与外面的系统交互





应用软件的安全问题日益突出



2008年WEB站点中存在的安全漏洞的统计
Jeremiah Grossman, Trey Ford (Blackhat2008,
Presentation)



OWASP Top Ten (2013 Edition)

A1: Injection

**A2: Broken
Authentication
and Session
Management**

**A3: Cross-Site
Scripting (XSS)**

**A4: Insecure
Direct Object
References**

**A5: Security
Misconfiguratio
n**

**A6: Sensitive
Data Exposure**

**A7: Missing
Function Level
Access Control**

**A8: Cross Site
Request
Forgery (CSRF)**

**A9: Using
Known
Vulnerable
Components**

**A10:
Unvalidated
Redirects and
Forwards**



新的需求与传统安全技术的不足

- 用户认证
 - ➔ 主机认证
 - NTKM
 - Kerberos
 - .net Passport
 - ➔ 证书认证
 - X.509
 - ➔ 网络认证
 - Radius
 - Diameter
 - IKE
 - ➔ HTTP协议只有较弱的认证技术
 - 基本认证rfc2617
 - 表单认证



新的需求与传统安全技术的不足

- 访问控制
 - Firewall
 - 针对网络的访问控制技术无法适用于WEB
- 攻击监控
 - IDS/IPS
 - 无法监控SSL/TLS等机密应用
- 监控用户状态
 - 可以监控TCP连接
 - Session/cookie机制的不足
- 阻止已知攻击
 - IPS
 - 应用层威胁很难被阻断



主要原因

- 传统网络安全技术只能对网络层进行防护
- 无法分辨与正常应用数据混杂在一起的攻击

→ XSS

→ SQL注入

→ 未校验参数

→ etc.

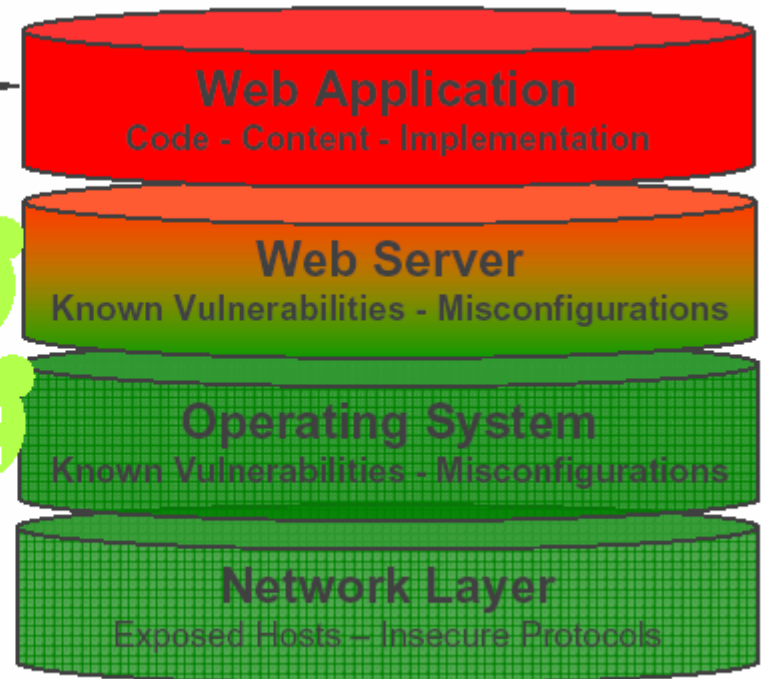


Web Application Attacks

Known Web Server Attacks

OS Attacks

Network Attacks





安全边界已经扩展到了系统源代码

Your security “perimeter” has huge holes at the application layer

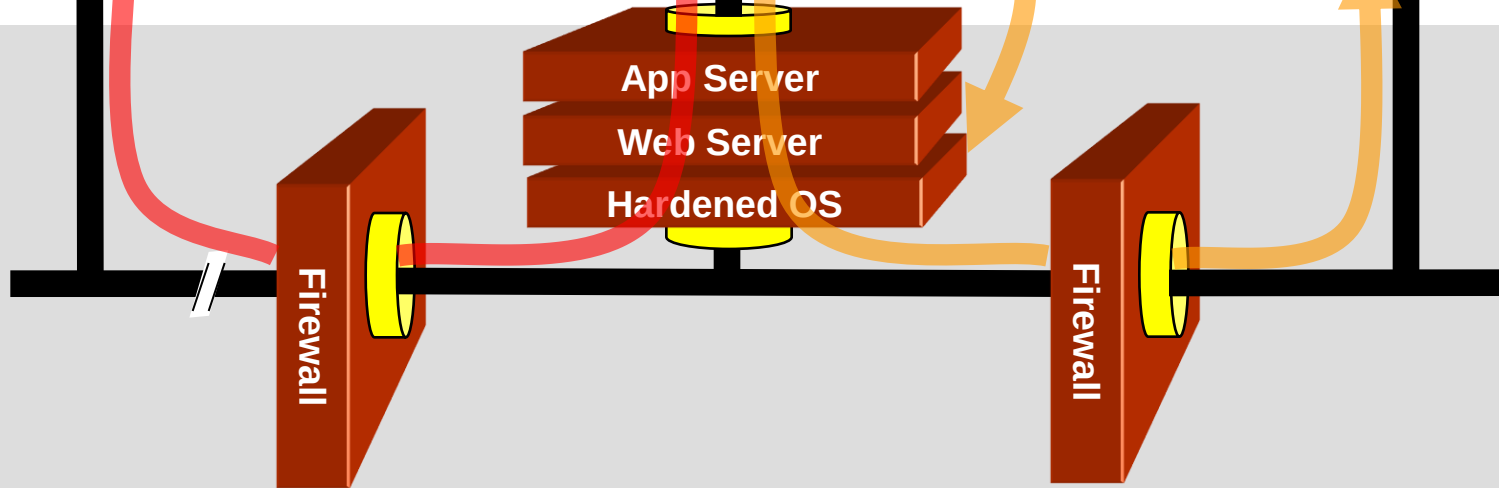
Application Layer



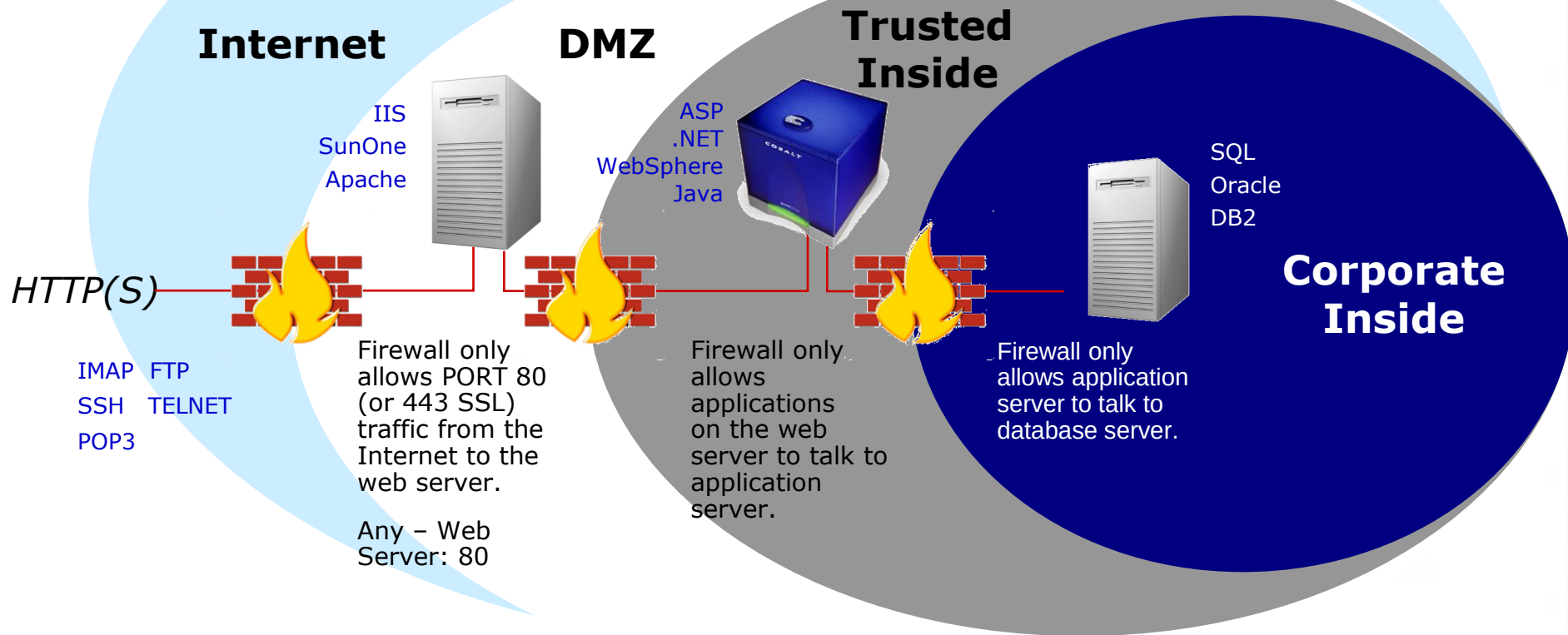
Custom Developed
Application Code

Databases
Legacy Systems
Web Services
Directories
Human Resrcs
Billing

Network Layer



不能使用网络层保护（防火墙，SSL，IDS等）来阻止应用层攻击

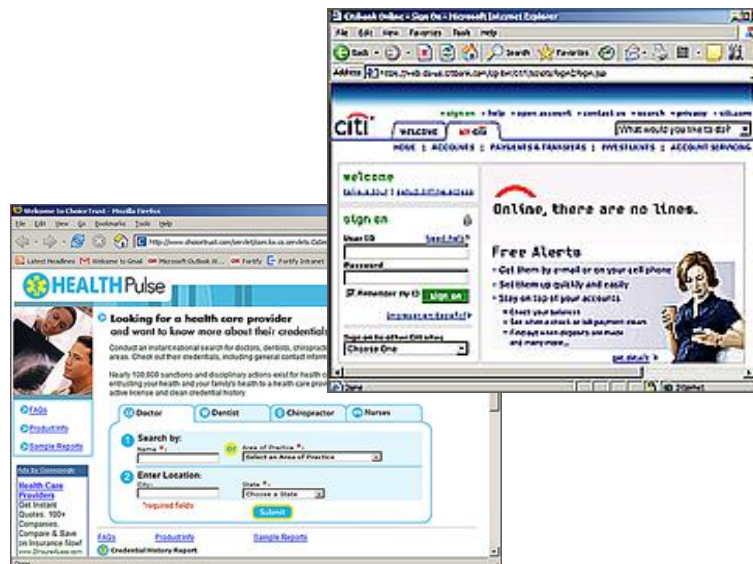
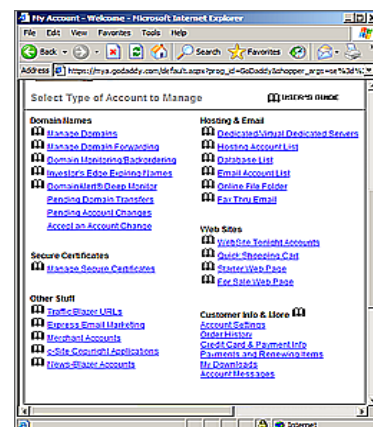




今天的黑客可直接利用软件的弱点达到攻击我们的系统

软件易于遭受的安全弱点:

- SQL注入
- 跨站脚本
- 缓冲区溢出
- 信息泄露
- 等等





Demo

- SQL注入
- 跨站脚本XSS
- 缓冲区溢出



软件必须保护自己

Outside:



- Source IP
- Destination IP
- Fragmented data
- HTTP requests?

Inside



- User sessions
- SQL queries
- Application variables
- Historical patterns



软件必须保护自己

Outside:



Inside



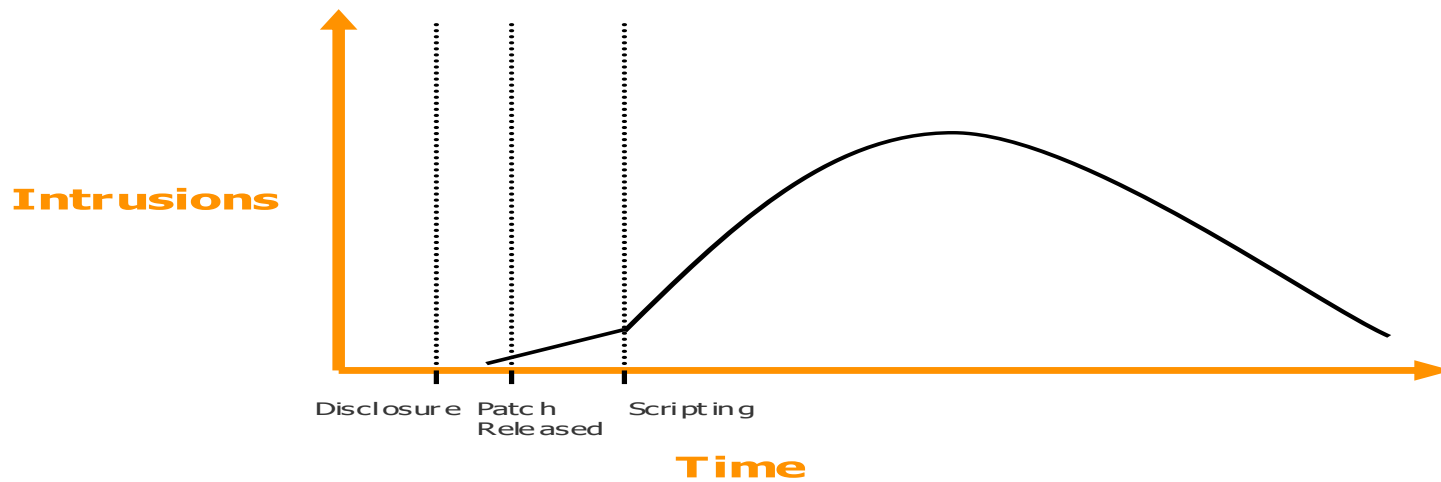


传统的安全思想

- 用防火墙来定义系统的“边界”,把软件与外界隔离.
- 过分依赖加密技术
 - SSL
 - IPSec
- 当产品要发布的时候才去Review产品
 - 以补丁(patch)的方式进行修复
- 不允许新技术使用:
 - 如果是新的,肯定有问题.
 - 直到这种技术成熟了,才使用.
 - 想尽一切办法去否定使用新技术的想法



渗透测试与补丁不是好方法



**Average Curve of Number of Intrusions for a Security Bug Over Time, as Reported
by
Arbaugh, Fithen and McHugh, 2000.**



传统的安全模式

- 保护“边界”
- 网络安全
- 安全负责的人是 IT/MIS/CISSP等部门
- 被动式



新的安全模式

- **构建安全的系统**
- **设计安全的软件**
- **软件开发人员和设计人员对安全负责**
- **主动式**



软件安全的根源问题

- 软件安全的问题是软件自身的缺陷问题,其主要在软件设计和软件实现的过程中产生,具体表现在软件设计的架构问题和实现上的错误.
 - 开发软件 - 造房子
 - 实现上的错误-软件代码错误- 墙的问题
 - 架构问题- 软件架构风险- 梁的问题
 - 在软件安全问题上,架构上的风险往往比实现上的分析更重要,更难理解.



4 主要解决途径—软件安全

- 概念:

- ➔ 为了安全目的设计、开发、测试软件的过程。
- ➔ 其通过在软件自身中确定和清除安全问题来达到计算机安全的目的。



软件安全主要涉及的领域

- 策略与管理

- ➔ 教育与培训

- ➔ 标准与规范

- 需求与设计

- ➔ 威胁建模

- ➔ 安全需求

- ➔ 防御设计



- 确认与评估

- ➔ 架构审查

- ➔ 代码审查

- ➔ 安全测试

- 部署与实施

- ➔ 弱点管理

- ➔ 基础加固

Building CWE & Consensus

Publicly Available: Security Taxonomies, Research, and Checklists

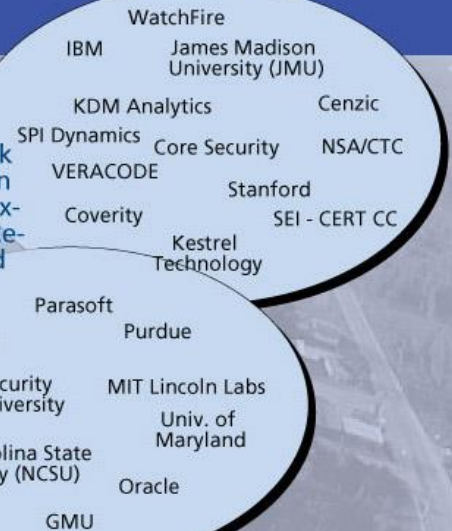


Preliminary

CVE-based Preliminary List of Vulnerability Examples for Researchers (PLOVER)

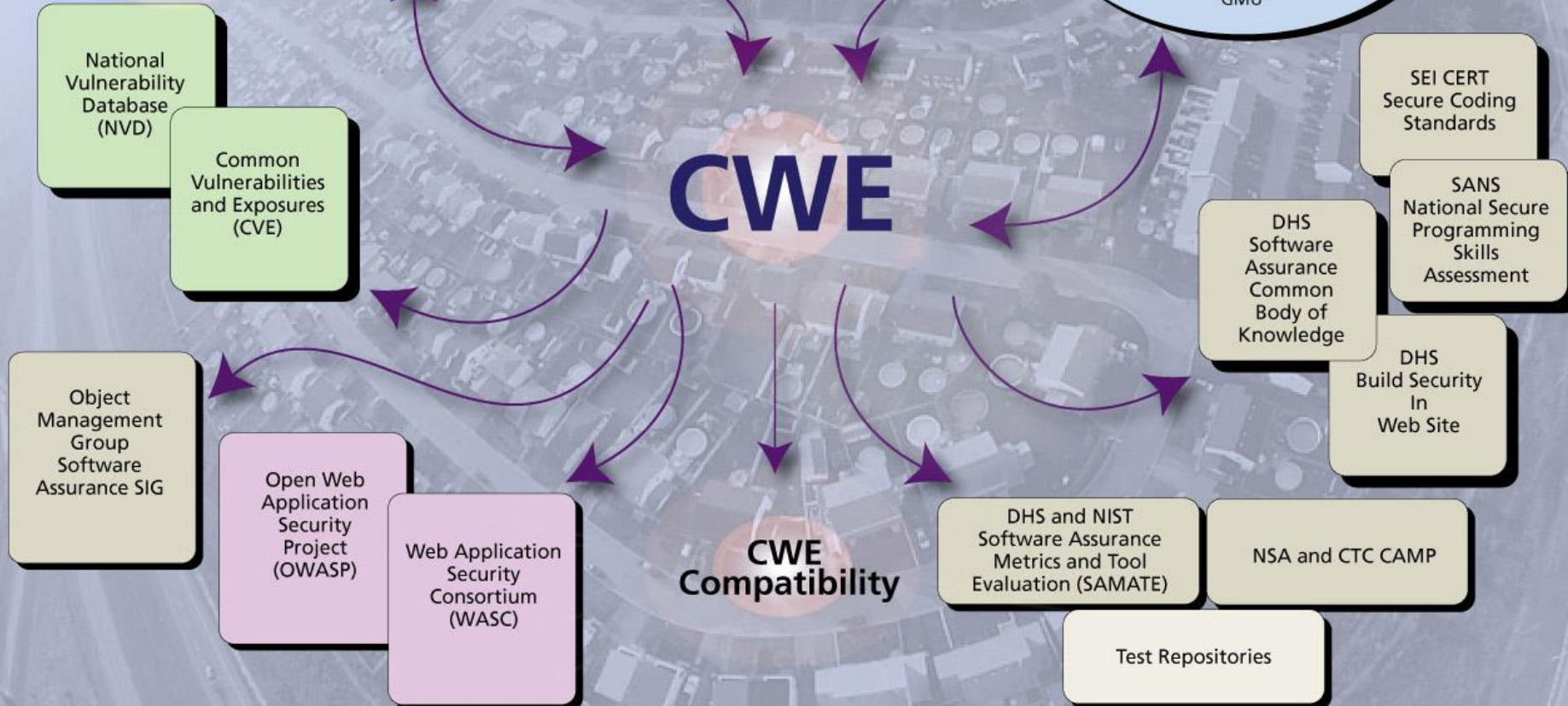
Previous Vulnerability Taxonomy Research

Other Work Available in Security Taxonomies, Research, and Checklists



CWE

CWE Compatibility





5 本课程主要内容

- 软件安全漏洞与缺陷
- 堆栈溢出
- 漏洞挖掘与fuzz测试
- Shellcode
- 安全编码技术
- 指针安全
- 字符串安全
- 格式化输出
- 整数安全



本课程的主要意义

- 介绍软件安全概念，普及软件安全意识。
- 使学生在学习阶段认识到软件开发中存在风险。
- 提倡安全软件开发，推广安全编码规范。
- 联系理论与实践，介绍软件安全功能的开发技术。



本课程的教学方式

- 课堂讲授
- 课堂演示
- 课下作业
- 课下自学

→ 软件开发基础

- 以C/C++为主



课件下载地址

链 接： <https://pan.baidu.com/s/1AtaRN-JEveu-WDeF9u79QQ>

提取码： 3mf5



主要参考书

- 编写安全的代码 第二版
 - (美) Michael Howard, Davide LeBlane 著
 - 程永敬 翁海燕 朱江涛 译
 - 机械工业出版社
- Software Security
 - (美) Gary McGraw 著
 - Addison-Wesley
- Secure Programming Cookbook for C and C++
 - (美) Matt Messier, John Viega
 - O'Reilly



课程参考资料

- 课件
- C和C++安全编码，第2版，机械工业出版社
- 0day安全：软件漏洞分析技术
 - ➔ 王清
 - ➔ 电子工业出版社



参考资料

- OWASP <http://www.owasp.org>
- 微软 <http://www.microsoft.com>
- BugTraq <http://www.securityfocus.com>
- CWE <http://cwe.mitre.org/>
- Fortify <http://www.fortifysoftware.com>
- CERT <http://www.cert.org>



北京邮电大学

谢谢观赏！
Thanks!

北京邮电大学

BEIJING UNIVERSITY OF POSTS AND TELECOMMUNICATIONS